

Least privilege, keys, trails, group access

Day 5 - Afternoon

Running scenario: Thara Hospitals patient portal pilot

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management



CONCEPT 1



Fixing Day 2

15 min

Two rules for this afternoon

- The long-lived key on `thara-web-1` is removed today, and an instance role replaces it
- The role's policy is **written first, tested in the simulator, then attached**
- Never the other way round

An untested policy on a live server gets its first test from the patients.

COMMON MISTAKE

A role is a user.

A role is assumed. It issues temporary credentials.

Three things to know before you start

- Attaching the role is not enough: the command line reads the old file first
- Removing the file is not enough: the key lives in IAM
- `thara-web-1` can reach S3 and nothing else, so every proof is an S3 command
- The volume and the analyzer carry the three tags and no name

COMMON MISTAKE

Deleting a key from the instance revokes it.

It must be deleted in IAM.

Least privilege, keys, trails, group access

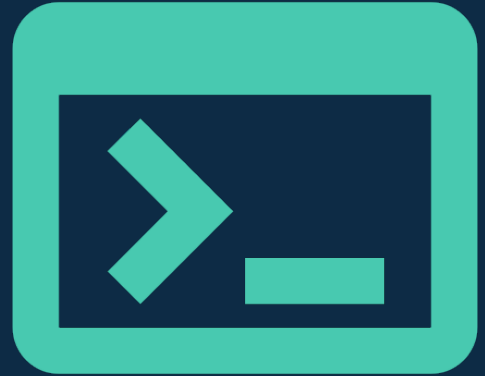
You build:

10

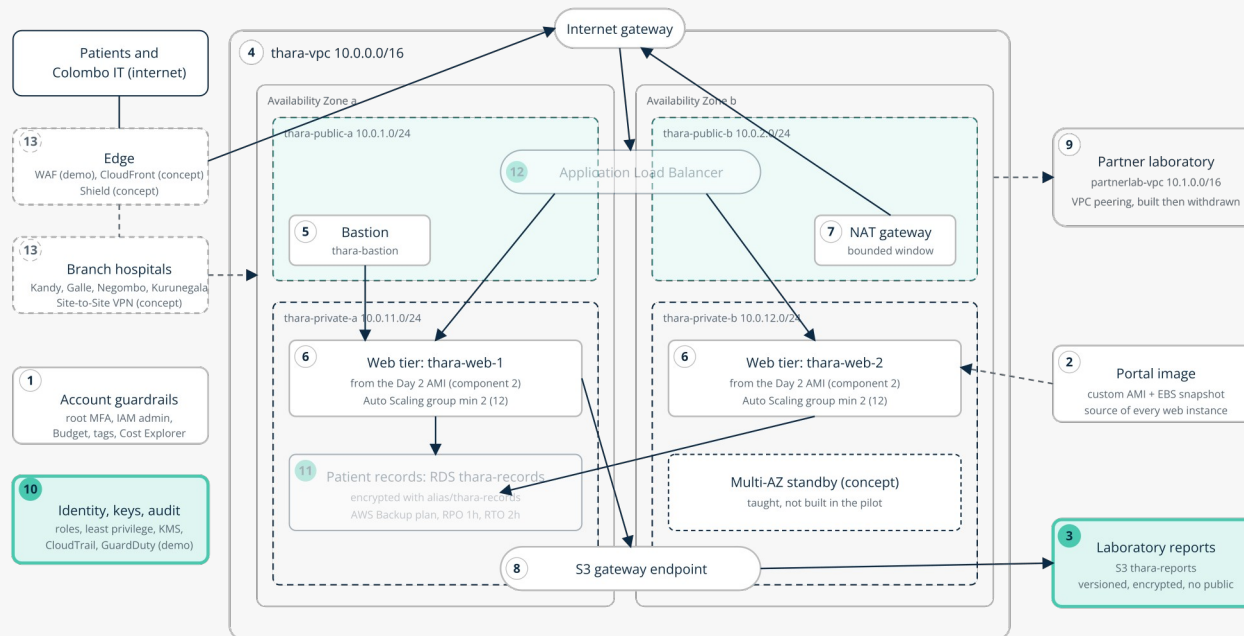
3

Estimated credit use: about USD 0.80

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management



The Thara architecture



TODAY

- 10** Identity, keys and audit
- 3** Laboratory reports bucket

KEY

- Built today
- Built earlier
- Concept only
- Not yet built

SEGMENT 1 - 45 MIN



Policy, simulator, role, instance profile

Cost: nil

Start, reopen the door, write the policy



1

Confirm the region is `ap-south-1` and that you are the admin user, not root.

Expected: Mumbai, and `admin-<student id>`, in the top bar.

2

Start `thara-bastion` and `thara-web-1`. Set the SSH source of `thara-bastion-sg` to My IP again. Connect, and hop to `thara-web-1`.

Expected: A prompt of the form `ec2-user@ip-10-0-11-...`

3

IAM, Policies, Create policy, JSON. Two statements. Name it `thara-reports-read`.

Expected: Listed as Customer managed.

The policy: two actions, one bucket



```
{ "Effect": "Allow",  
  "Action": "s3:ListBucket",  
  "Resource": "arn:aws:s3:::thara-reports-<student id>" },  
{ "Effect": "Allow",  
  "Action": "s3:GetObject",  
  "Resource": "arn:aws:s3:::thara-reports-<student id>/*" }
```

Listing acts on the bucket. Reading acts on the objects in it: that is the /*.

Simulate, then build the role



4 IAM, Policy simulator, custom mode. Paste the policy. Test `GetObject` and `PutObject` on a report, and `ListBucket` on `thara-audit-<student id>`.

Expected: Allowed; implicitly denied; implicitly denied.

5 Roles, Create role: AWS service, EC2, the policy `thara-reports-read`. Name it `thara-web-role`. Read its trust tab.

Expected: One policy. The trust names `ec2.amazonaws.com`.

6 EC2, `thara-web-1`: Actions, Security, Modify IAM role. Choose `thara-web-role`.

Expected: The Security tab shows the role.

SEGMENT 2 - 15 MIN



Remove the key; prove access still works

Cost: nil

Which credentials is the server using?

7 On `thara-web-1`, list the bucket, then ask the command line where its credentials come from.

Expected: The listing fails. Type reads `shared-credentials-file`.

8 Remove the file. Then in IAM, delete the Day 2 key and its `.csv` file.

Expected: Type now reads `iam-role`. The admin user has no access keys.

```
$ aws s3 ls s3://thara-reports-<student id>
$ aws configure list
$ rm ~/.aws/credentials
$ aws configure list
```

Prove the role, and its limits

9

List the bucket. Try an upload. Try to list every bucket.

Expected: The listing works. The other two are denied: no identity-based policy allows them.

```
$ aws s3 ls s3://thara-reports-<student id>
$ echo "upload test" > /tmp/upload-test.txt
$ aws s3 cp /tmp/upload-test.txt \
$     s3://thara-reports-<student id>/
$ aws s3 ls
```

The lab sheet adds one command that shows when the credentials expire.

SEGMENT 3 - 30 MIN



KMS key and encrypted volume

Cost: the key is about USD 1 per month, prorated

A key you own, and an encrypted volume

10 KMS, Customer managed keys, Create key: Symmetric, alias `thara-records`. Administrator and user: your admin user only.

Expected: Enabled, as `alias/thara-records`. The role is not in its key policy.

11 Snapshots, the Day 2 data volume: Create volume from snapshot, zone a, Encrypt this volume, that key. Attach to `thara-web-1` as `/dev/sdf`. Mount and read.

Expected: The Day 2 line prints. The volume shows the key's alias.

```
$ sudo mkdir -p /data
$ sudo mount /dev/nvme1n1 /data
$ cat /data/reports-index.txt
```

SEGMENT 4 - 20 MIN



CloudTrail trail

Cost: first trail free; audit bucket negligible

The trail, and finding yourself in it

12 CloudTrail, Create trail: `thara-trail`, Create new S3 bucket `thara-audit-<student id>`. Clear Log file SSE-KMS encryption. Management events.

Expected: Logging, multi-region. The bucket has Block all public access on.

13 Add an HTTPS rule from `thara-bastion-sg` to `thara-web-sg`, then delete it. In Event history, filter by Resource name with the group's id.

Expected: Two events with your user name, the time and your address.

Left ticked, SSE-KMS creates a second key with a charge of its own.

SEGMENT 5 - 15 MIN



GuardDuty and Access Analyzer

Cost: 30-day trial

Two watchers



14 Enable GuardDuty. Then IAM, Access analyzer, Analyzer settings, Create analyzer: External access, the offered name, Current account.

Expected: No findings yet. The analyzer becomes Active.

Write the trial's last day in your ledger. If your plan refuses GuardDuty, record the message.

SEGMENT 6 - 25 MIN



Group member access in the host account

Cost: nil

The group's access, in the host account

15 Create the group `thara-capstone` and a user for each member other than the host, named by tier and student id.

Expected: A member can sign in and can do nothing yet.

16 Complete `thara-capstone-network`, `thara-capstone-security` and `thara-capstone-data` from the lab sheet. Simulate each. Attach. Each member signs in.

Expected: One page that works and one that is refused, for each member. Three JSON files.

Agree what goes in each gap before the host types it.

SEGMENT 7 - 15 MIN



Optional credit harvest; ledger; evidence

Cost: nil

Optional, then the ledger



- 17** Optional, not examined: the two remaining activities in the Explore AWS widget. Delete what they create.
Expected: The widget shows them as completed.

Then: ledger rows, prove it, break it, teardown, evidence.

Prove it, then break it



PROVE IT

- From `thara-web-1`, with no credentials file: the listing succeeds and the upload is denied
- The encrypted volume shows the KMS key alias
- The security group change is in CloudTrail with your user name
- Each member's sign-in test: one allowed, one denied

BREAK IT

- Attach the inline policy `thara-deny-test` to `thara-web-role`: Deny, `s3:*`
- The listing is denied. Read the whole message
- Confirm in the simulator, then remove it

Tear down and record



TEARDOWN

- Unmount, detach and delete the encrypted volume. Keep the snapshot
- Keep the role, the key, the trail, the audit bucket, GuardDuty and the group users
- Stop `thara-bastion` and `thara-web-1`

COST

Estimated credit use: about USD 0.80

FOR YOUR EVIDENCE PACK

- The tested policy JSON and the simulator result screenshot
- The CloudTrail event for the security-group change
- One-page security review memo: findings from the threat walk and today's remediations
- Group: the three tier policies as JSON and the member sign-in test record

Common mistakes



COMMON MISTAKE

A role is a user.

A role is assumed. It issues temporary credentials.



COMMON MISTAKE

Deleting a key from the instance revokes it.

It must be deleted in IAM.

Before the next session



READ

Amazon RDS User Guide

"Backups and restores" overview. Also the AWS Backup Developer Guide, "Getting started".

SELF-CHECK

CLF-C02 bank

Domain 3 database set, 10 items.

PQ5 is due.

TASK

Your group

Begin the capstone network build in the host account.

Questions & Discussion



Next: storage strategy, managed databases and recovery.



Disclaimer & Copyright



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability of the content within this presentation.

Cloud services, prices and free-tier terms change. Figures in this presentation were correct when prepared; check the provider's current documentation before relying on them.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites, and I am not responsible for their content.

Thara Hospitals (Pvt) Ltd is a fictional organisation created for teaching. AWS and Amazon Web Services are trademarks of Amazon.com, Inc. or its affiliates; this material is not affiliated with or endorsed by AWS.



© 2026 Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content licensed under CC BY-NC-SA 4.0. Images and artworks used for explanation may contain third-party material used under fair dealing for education.

Revision f799579